

Capítulo
05

La gestión del riesgo

Objetivos

Comprender, describir y evaluar el proceso de gestión del riesgo.

Conceptos

Definición de la gestión del riesgo, el análisis/evaluación de riesgos y la aceptación, el procesamiento y la comunicación de los riesgos.

5.1 Definiciones

Ejercicio de nivelación – gestión del riesgo

- » ¿Qué es riesgo para usted?
- » ¿Qué entiende usted por gestión del riesgo?

Riesgo de seguridad es una combinación de amenazas, vulnerabilidades e impactos. Las amenazas son eventos que aprovechan las vulnerabilidades (debilidades) y pueden causar daños. El impacto es el resultado de una vulnerabilidad al ser explotada por una amenaza.

En cuanto a la gestión del riesgo, algunas definiciones se consideran importantes y se presentan a continuación:

- » La gestión del riesgo incluye todas las medidas adoptadas para controlar los riesgos en una organización, incluyendo el análisis/evaluación, el tratamiento, la aceptación y la comunicación de los riesgos.
- » El análisis de riesgos identifica y estima los riesgos, teniendo en cuenta el uso sistemático de la información. Abarca el análisis de las amenazas, vulnerabilidades e impactos y se considera el punto clave de la política de seguridad de la información de una organización.
- » La evaluación del riesgo compara el riesgo estimado en el análisis con los criterios predefinidos con el fin de identificar la importancia de cada riesgo para la organización.
- » Aceptación de riesgos incluye la identificación del nivel aceptable de riesgos para una organización en función de sus necesidades específicas de negocio y seguridad.
- » El tratamiento del riesgo corresponde a la selección y la aplicación de medidas para modificar un determinado riesgo.

La comunicación de riesgos involucra iniciativas para mostrar los riesgos a los empleados, directivos y terceros (estos últimos, cuando sea apropiado y necesario).

5.2 Cuestiones claves

Para llevar a cabo una gestión eficaz del riesgo, es necesario identificar inicialmente, las amenazas y los impactos, la probabilidad de la materialización de las amenazas y riesgos potenciales. Se recomienda clasificar los riesgos según los criterios: nivel de importancia, gravedad de las pérdidas y costos involucrados en la prevención o recuperación de desastres.

Si el costo para evitar una amenaza es mayor que su daño potencial, es aconsejable tener en cuenta otras medidas. Las decisiones deben ser tomadas teniendo en cuenta la importancia que tiene para la continuidad del negocio de la organización el activo amenazado.

Tenga en cuenta que el análisis de las amenazas y vulnerabilidades busca identificar la probabilidad de ocurrencia de cada evento adverso y las consecuencias de los daños, mientras que el análisis de impacto debería identificar los recursos críticos para la organización; es decir, los que más sufren con los daños.

Dado que es muy difícil definir con precisión la probabilidad de que una amenaza ocurra y los respectivos daños causados, se recomienda establecer una lista de amenazas potenciales, de los recursos afectados, de los requisitos de seguridad afectados y el grado de impacto (por ejemplo, muy alto, alto, moderado, bajo y muy bajo).

5.3 La gestión del riesgo

La gestión del riesgo debe considerar los siguientes tres niveles de aplicación: tecnologías, procesos y personas. La tecnología garantiza los ajustes técnicos necesarios para el tratamiento adecuado de los riesgos; los procesos de asegurar que las actividades que componen la gestión de los riesgos sean consideradas de forma sistemática, y, por último, las personas, de modo que los empleados y los gerentes identifiquen sus responsabilidades, conozcan los riesgos y puedan ayudar a su reducción y control. Instrumentos como la política de seguridad y un código de conducta se recomiendan en su contexto.

En cuanto a las medidas de seguridad, se recomienda atención a las siguientes categorías: preventivas, de carácter estructural (por ejemplo, una política formal para el control de acceso lógico); correctivas, como una emergencia (planes de contingencia, por ejemplo), e ilustrativas, con carácter educativo (entrenamientos, folletos, conferencias, etc.).

Figura 28.
Secuencia para el cambio de comportamiento y la prevención de riesgos

En particular, recuerde que la orientación y la información son esenciales para la reducción de riesgos. Por lo tanto tenga en cuenta la importancia del siguiente flujo de gestión del riesgo: información - conocimiento - cambio de conducta - educación - prevención de los riesgos.



Ejercicio de refuerzo - gestión del riesgo

- » ¿Cuáles son los tres niveles a tener en cuenta en la gestión del riesgo?

5.4 Análisis y evaluación de riesgos

En esta sección, se presentan los aspectos relevantes para el análisis/evaluación de los riesgos en las organizaciones. En particular, se presentarán algunas clasificaciones para análisis de impacto, definición de probabilidades y cálculos de riesgo.

Identifica, califica/cuantifica y prioriza los riesgos de seguridad de la información. Es esencial para:

- » Gestión del riesgo.
- » Proposición de medidas de seguridad apropiadas.

Consideraciones:

- » Deben ser sistemáticas.
- » Deben utilizar métodos concretos.
- » Se deben realizar periódicamente.

El análisis/evaluación de riesgos consiste en identificar, cuantificar y calificar los riesgos de seguridad de la información, con base en los objetivos de la organización. Incluye también la priorización de los riesgos, teniendo en cuenta los criterios de riesgo aceptable. Es una actividad que indica la forma de garantizar una gestión adecuada de la información sobre riesgos de seguridad y un conjunto adecuado de medidas de seguridad de la organización en cuestión.

Algunos aspectos de análisis / evaluación de riesgos que deben ser contemplados son:

- » Deben ser llevados a cabo de manera sistemática con el fin de identificar los riesgos (análisis) y calificar el riesgo (evaluación). El análisis de riesgo mide las amenazas, vulnerabilidades, impactos y actividades en un ambiente determinado con el fin de orientar la adopción de las medidas adecuadas al negocio y a los requisitos de seguridad de la organización.
- » Debe utilizar métodos específicos para permitir la comparación entre los resultados obtenidos y su reproducción.
- » Debe realizarse periódicamente o cuando los requisitos de seguridad, activos, vulnerabilidades y / o los objetivos de negocio sufren algún cambio.

5.5 Analizando los riesgos

El análisis de riesgo debe considerar los daños probables al negocio resultantes de fallas de seguridad; la probabilidad de que las fallas ocurran frente a las vulnerabilidades y amenazas existentes; y las medidas de seguridad implementadas (si es aplicable) para que al final, se recopilen los datos necesarios para la adecuada gestión del riesgo.

Por lo tanto, algunas preguntas deben ser contestadas:

- » ¿Qué hay que proteger?
- » ¿Cuáles son las vulnerabilidades y amenazas?
- » ¿Cómo analizar?

La respuesta a estas preguntas es esencial para la ejecución y generación de resultados en el análisis de riesgos.

5.6 ¿Que hay que proteger?

En esta etapa, se deben considerar todos los activos involucrados en el alcance del SGSI de la organización, especialmente los directamente relacionados con los objetivos del negocio. Por lo tanto, se trata de una fase que no puede ser subjetiva, es decir, se recomienda hacer un inventario cuidadoso de los activos, teniendo en cuenta parámetros y categorías de selección, por ejemplo.

En particular, usted debe examinar primero las amenazas y vulnerabilidades de los activos a ser protegidos, de modo que sean considerados todos los eventos adversos que tal vez pueden explotar las debilidades de seguridad de la organización, causando daños.

Hardware, software, datos, personas, documentos, sistemas de información, contratos, entre otros, son ejemplos de activos considerados cruciales para el negocio de la organización.

Ejercicio de refuerzo -qué proteger

- » Cite ejemplos de activos críticos en su organización.

5.7 Vulnerabilidades y amenazas

Después de identificar los activos que deben ser protegidos en la organización, se deben considerar las probabilidades de cada activo de ser vulnerable a las amenazas. Para ello, hay que prestar atención a la información que pueda quedar comprometida, creando listas de prioridades, por ejemplo; y los servicios de seguridad que puedan verse comprometidos, tal como la confidencialidad, integridad y disponibilidad.

Ejemplos de amenazas típicas:

- » Desastres naturales.
- » Falta de suministro de energía eléctrica.
- » Robo/estafa
- » Amenazas programadas.
- » Fallas de hardware.
- » Fallas de software.
- » Errores humanos.

A continuación se presentan algunas de las amenazas típicas en entornos de las TI:

- » Los desastres naturales que afectan a la instalación física de la organización. Durante el desastre, los controles de acceso físico pueden verse comprometidos y algunos recursos con información sensible se pueden violar con facilidad.
- » Las fallas en el suministro eléctrico, que afectan a la parte de hardware de la organización. Con el hardware dañado, los servicios no estén disponibles.
- » Amenazas programadas tales como virus y bombas lógicas que afectan software. Por lo tanto, los códigos no autorizados pueden revelar la información confidencial al mundo exterior, tal como contraseñas.
- » Las fallas de hardware. De este modo, la máquina comprometida puede ser enviada a mantenimiento sin el previo cuidado de borrar la información confidencial contenida en los mismos.
- » Las fallas de software, corrompiendo los datos.
- » Los errores humanos que afectan a cualquier sistema de la organización, permitiendo así la revelación de información confidencial; por ejemplo, imprimir información confidencial en una impresora pública.

El análisis de riesgos debe medir las amenazas, las vulnerabilidades y los impactos de modo que el resultado pueda servir como guía para la adopción de medidas de seguridad adecuadas a los requisitos de negocio de la organización, teniendo en cuenta, por lo tanto, costos asociados, nivel de protección requerido por los activos y facilidad de uso.

En particular, se puede considerar el análisis de riesgos en términos cualitativos, con el fin de cumplir con los requerimientos del negocio, o en términos cuantitativos, con el fin de asegurar que los costos de las medidas preventivas, correctivas e ilustrativas no superen el valor del activo en cuestión, en lo que se refiere al patrimonio de la organización y también a la continuidad del negocio.

Tabla 2. Datos de ejemplo para una organización en particular

Tipo de datos	Clasificación	Importancia
Resultado clínico	Búsqueda	Alto
Estudio de mercado	Búsqueda	Bajo
Patentes dependientes	Propietario	Alto
Memorandos	Administrativo	Bajo
Los sueldos de los empleados	Financiero	Medio
Características de producto nuevo	Propietario	Medio

En el ejemplo, se consideró que el activo “datos” y además los objetivos de negocio de una organización determinada para establecer una clasificación de los datos (administrativos, financieros, cliente, investigación, propietario) y la debida importancia dada a cada categoría.

5.8 Análisis de los impactos

El impacto es el resultado cuando se produce una amenaza. Así, por ejemplo, teniendo en cuenta los controles de acceso inadecuados, podemos mencionar los impactos tales como la modificación no autorizada de datos y aplicaciones y la revelación no autorizada de información, lo cual, a su vez, causa problemas directos para la organización. Por lo tanto, es importante analizar los impactos, con miras a la gestión apropiada de riesgos dentro de la organización.

Para el análisis de los impactos, se puede considerar una propuesta de clasificación específica de apoyo. Por lo general, los impactos de las amenazas a la organización se analizan desde dos aspectos: a corto y largo plazo, teniendo en cuenta el periodo de tiempo durante el cual un impacto permanece afectando a los negocios.

Se puede considerar la siguiente propuesta para categorizar los impactos:

- » 0. impacto irrelevante;
- » 1. Efecto poco significativo que no afecta la mayoría de los procesos de negocio de la institución;
- » 2. Los sistemas no están disponibles por un determinado periodo de tiempo, puede causar la pérdida de credibilidad e imagen

- de la organización además de pequeñas pérdidas financieras;
- » 3. Pérdidas financieras a gran escala y la pérdida de clientes;
- » 4. Efectos desastrosos, pero que no comprometen la supervivencia de la organización;
- » 5. Efectos desastrosos que comprometen la supervivencia de la organización.

Ejercicio de refuerzo - análisis de impacto

- » Explique qué es un análisis de impacto

5.9 Matriz de relaciones

La matriz de relaciones es una forma simplificada de visualizar las amenazas, impactos y las probabilidades de acuerdo con el ejemplo propuesto, es decir, en relación con cada amenaza potencial en la organización, su impacto y probabilidad de ocurrencia. Por ejemplo, las categorías de 0 a 5 para cada elemento se pueden usar, como se discutió anteriormente.

Tabla 3. Amenazas versus Impactos versus Probabilidades

Amenazas	Impacto	Probabilidad
Errores humanos		
Instalación de hardware y software no autorizado		
Códigos maliciosos		
Errores en los sistemas operativos		
Invasión		
Desastres naturales		
Desastres causados por personas		
Fallas del equipo		
Sabotaje		
Chuzadas telefónicas		
Monitoreo del tráfico de la red		

Continuación tabla 3. Amenazas versus Impactos versus Probabilidades

Amenazas	Impacto	Probabilidad
Modificación de la información		
Acceso a los archivos de contraseñas		
Uso de contraseñas débiles		
Monitoreo del tráfico de la red		
Usuarios internos que practican actos ilegales		

Ejercicio de refuerzo - la matriz de relación

- » Rellene el cuadro anterior de Amenazas X Impacto X Probabilidad con valores de 0 a 5 de acuerdo con el entorno de las TI de su organización

5.10 Cálculo del riesgo

Los riesgos se calculan a partir de la relación entre el impacto y probabilidad de ocurrencia, es decir, $\text{riesgo} = \text{impacto} * \text{probabilidad}$

En particular, teniendo en cuenta las calificaciones de impacto y probabilidad presentado anteriormente, al realizar la multiplicación, obtenemos un rango de valores para el riesgo del 0 (sin riesgo) a 25 (muy alto riesgo). Entonces se puede considerar esta propuesta general, por ejemplo, para el cálculo de los riesgos generales de la organización y proponer las medidas de seguridad adecuadas a su debido tratamiento, teniendo en cuenta, por lo tanto, un nivel aceptable de riesgo, dado que no todos los riesgos debido a los costos, tienen la garantía de ser reducidos por medio de medidas de seguridad.

5.11 La evaluación de riesgos

Al evaluar los riesgos se busca una base que sirve para fines de comparación, por ejemplo, el análisis y la evaluación de riesgos realizada en temporadas anteriores. El conocimiento previo de los impactos y las probabilidades de riesgo siempre es relevante para una evaluación adecuada y completa.

Por otro lado, hay básicamente dos formas de realizar la evaluación del riesgo:

- » **Cualitativo:** evaluación de riesgos a través de la estimación cualitativa es la que utiliza calificadores y atributos descriptivos para evaluar. No se asignan valores financieros. Se considera muy subjetiva. Ejemplo: Alto, Medio, Bajo, Muy Bajo.
- » **Cuantitativo:** evaluación de riesgos a través de una estimación cuantitativa es aquella que utiliza valores numéricos financieros para cada uno de los componentes recolectados durante la identificación de los riesgos. Ejemplo: 50% de probabilidad; el impacto: \$ 100.000.000.

En los siguientes ejemplos se hacen dos análisis de riesgo realizados en el mismo entorno, pero con diferentes formas de calcular el riesgo. Tenga en cuenta los criterios que se utilizan en cada uno.

5.11.1 Ejemplo 1: análisis de riesgos

En una Institución de Educación Superior, IES, se decidió que el área de las TI llevara a cabo una evaluación de riesgos de la red administrativa en tres departamentos: ingeniería, finanzas y administración. Para esto se utilizó como metodología el concepto de riesgos como consecuencia de la probabilidad multiplicada por el impacto, con los parámetros cualitativos alto, medio y bajo, con los pesos asignados a cada uno para el cálculo del riesgo. Después de realizar la etapa de análisis de los riesgos, usted realizó la evaluación de riesgos, llegando al resultado a continuación:

Tabla 4. Los resultados de la evaluación de riesgos.

Área	Probabilidad de que ocurra		Impacto en caso de producirse		Riesgo = P x I	
	Evaluación	Peso	Evaluación	Peso	Evaluación	Peso
Departamento de ingeniería	Media	2	Medio	2	4	Medio
Departamento administrativo	Media	2	Bajo	1	2	Bajo
Departamento financiero	Media	2	Alto	3	6	Alto

Tabla 5. Criterio utilizado de probabilidad

Criterio de probabilidad		Peso
Alta	Ha ocurrido con frecuencia mensual	3
Media	Ocurrió al menos una vez en los últimos seis meses	2
Bajo	No hay registro/historia de ocurrencia	1

Tabla 6. Criterio utilizado de impacto

Criterio de impacto		Peso
Alto	Si ocurre causará grandes pérdidas financieras	3
Medio	En este caso las pérdidas causan impacto financiero hasta \$10.000000	2
Bajo	En este caso las pérdidas no causarían impacto financiero	1

Tabla 7. Criterio utilizado de riesgo

Riesgo	
Alto	>4
Medio	> 2 y ≤4
Bajo	≤2

5.11.2 Ejemplo 2: análisis de riesgos

En una IES se determinó que el área de las TI realizará una evaluación de riesgo de la red administrativa en tres departamentos: ingeniería, finanzas y administración. Para esto fue utilizada una metodología desarrollada por una firma consultora que calcula los riesgos de la institución a través de una fórmula que utiliza parámetros como la criticidad, la disponibilidad, la confidencialidad entre otros. Después de realizar la etapa de análisis de los riesgos, usted realizó la evaluación de riesgos, llegando al siguiente resultado.

Tabla 8. Resultado de la evaluación de riesgos

Área	Criticidad de la red	Disponibilidad de la red	Confidencialidad de la red	Importancia de la red	EO	ED	RR
Departamento de ingeniería	2	3	1	6	0.1	0.3	3.8
Departamento administrativo	2	3	2	12	0.5	0.5	3.0
Departamento financiero	2	3	3	18	0.3	0.3	8.8

Tabla 9. Los valores de los criterios de criticidad, disponibilidad y confidencialidad

Riesgo	
Alto	> 4
Medio	$> 2 \text{ y } \leq 4$
Bajo	≤ 2

Tabla 10. Valores para evitar la ocurrencia y la degradación

Valores EO y ED	
Muy baja	0.1
Bajo	0.3
Moderado	0.5
Alto	0.7
Muy alto	0.9

Tabla 11. Convenciones utilizadas

Convenciones		
IR	Importancia de la Red	¿Cuál es la importancia de la red para los negocios?
EO	Evitar la Ocurrencia	¿Cuál es la probabilidad actual de evitar la ocurrencia?
ED	Evitar la Degradación	¿Cuál es la capacidad actual para prevenir la degradación?
RR	Riesgo Relativo	$IR * [(1-ED) * (1-ED)]$ Cálculo del riesgo en esta metodología

Para el ejemplo mostrado, el activo analizado es la red de la organización. Como se puede ver, ciertas convenciones se han utilizado para mapear la importancia de los servicios específicos de seguridad, tales como la disponibilidad, integridad y confidencialidad en un análisis, y en el otro sólo la probabilidad y el impacto. Al final, el resultado expresado se genera a partir de la propuesta para la medición de los riesgos de esa organización.

Determina los criterios para indicar si un riesgo es aceptable. Aspectos a tener en cuenta:

- » Los requisitos legales y de seguridad.
- » Los objetivos organizacionales.
- » Costo x beneficio.

Esta es una actividad que tiene por objeto determinar los criterios a considerar para indicar si un riesgo es aceptable o no para la organización.

Un riesgo se considera aceptable cuando, por ejemplo, después de la evaluación, se considera bajo o su tratamiento representa costos no viables para la organización.

Para determinar si un riesgo es aceptable o no, algunos aspectos deben tenerse en cuenta:

- » Los requisitos legales, reglamentarios, contractuales y de seguridad;
- » Objetivos de negocio;
- » Relación costo-beneficio para la adquisición/implementación de las medidas de seguridad en relación con los riesgos que deben ser reducidos.

Ejercicio de refuerzo - evaluación de riesgos

- » ¿Qué es y cómo se debe determinar el riesgo aceptable?

5.12 El tratamiento de los riesgos de seguridad

Después de la revisión, evaluación y definición de criterios aceptables para los riesgos en la organización, se debe indicar el procedimiento para el tratamiento de los riesgos. Entre las alternativas de tratamiento se destacan:

- » Seleccionar y aplicar las medidas de seguridad adecuadas para reducir los riesgos a un nivel aceptable (según los criterios definidos en la "Aceptación del Riesgo");
- » Implementar medidas de prevención frente a los riesgos, no permitiendo que las vulnerabilidades sean explotadas para la materialización del riesgo;
- » Transferir los riesgos a terceros mediante contratos con las compañías de seguros, por ejemplo.

Recuerde que los riesgos de seguridad varían según la ubicación (escenario o contexto) y, por lo tanto, es importante tener en cuenta este hecho para determinar las medidas de seguridad más adecuadas.



Preste atención al implementar medidas de seguridad, dependiendo de la organización, estas pueden ser no viables. Por ejemplo, la aplicación de registros (*logs*) para todas las actividades del usuario puede ir en contra de la legislación vigente y la privacidad de las personas en su entorno de trabajo.

Es de destacar también que supervisar, evaluar y proponer mejoras regularmente en las medidas de seguridad y, por lo tanto, el tratamiento del riesgo, es bueno para aumentar la eficacia de las prácticas de gestión del riesgo en la organización.

Ejercicio refuerzo - tratamiento de los riesgos de seguridad

- » ¿Cuáles son los objetivos del tratamiento del riesgo?

El tratamiento del riesgo es una actividad que se realiza después de la análisis/evaluación de riesgos de la organización, con el objetivo de ayudar a reducir los riesgos a un nivel aceptable. Por lo tanto, el uso de procedimientos y medidas de seguridad debe aplicarse en esta actividad, bien sea con medidas preventivas, correctivas o ilustrativas.

Es de destacar que cualquier medida que implica un seguimiento regular de las personas y/o sistemas debe ser implementado de acuerdo con la legislación vigente.

En cuanto al tratamiento de los riesgos de seguridad, algunas áreas se consideran esenciales para la organización para garantizar sus objetivos de negocio. Se destacan entre estas áreas, las preocupaciones como riesgos, impactos y el debido tratamiento para recursos humanos, seguridad de acceso y de comunicaciones, además de los negocios.

- » Seguridad de recursos humanos.
- » Seguridad de acceso.
- » Seguridad de las comunicaciones.
- » Seguridad y negocios.

Ejercicio de refuerzo - tratamiento de los riesgos

- » ¿Cuáles son las áreas claves de su organización para asegurar sus objetivos de negocio?

En este tema serán presentados varios ejemplos de los riesgos, los impactos y los tratamientos adecuados para garantizar que las organizaciones contemplan la seguridad en términos de recursos humanos, controles de acceso, la comunicación y los negocios.

Es de destacar que existen otras preocupaciones relevantes sobre los riesgos y los impactos en los organismos de seguridad, sin embargo, fueron tratados en este capítulo los cubiertos en la norma ISO/IEC 27002:2007 y aplicables independientemente de la rama de negocio de la organización.

5.13 Tratamiento de los riesgos en la seguridad de los recursos humanos

Las personas deben ser conscientes de sus responsabilidades y los riesgos y amenazas de seguridad. También debe estar alerta a los eventos adversos que representan riesgos.

Una buena práctica se recomienda para minimizar los riesgos de seguridad en las organizaciones y educar, sensibilizar y capacitar (cuando sea necesario) los recursos humanos: empleados, contratistas, socios, etc. En particular, algunas prácticas también ayudan a lograr este objetivo:

- » Asegurar que las personas conozcan, entiendan y cumplan con sus responsabilidades en la reducción de los riesgos de seguridad de la organización, especialmente en términos de robo, fraude y el uso indebido de los recursos y la información;
- » Las personas deben ser conscientes de que es importante notificar a sus superiores sobre cualquier evento adverso que represente riesgos (potenciales o reales) para la seguridad de la organización;
- » Las personas deben conocer los posibles riesgos y amenazas de seguridad con el fin de comprender su papel en lo que se refiere a seguridad de la información en la organización. En particular, cada uno debe hacer sus acciones de acuerdo con la actual política de seguridad, lo que reduce la ocurrencia de errores humanos y por lo tanto los riesgos.

Ejercicio de refuerzo - tratamiento de los riesgos en la seguridad de los recursos humanos

- » ¿Qué medidas va a proponer para el tratamiento de los riesgos de seguridad de los recursos humanos en su organización?

5.14 El tratamiento del riesgo en la seguridad de acceso

Al considerar la seguridad de acceso, en un principio hay una preocupación relevante con factores de riesgo para el contexto, tal como las responsabilidades asignadas a los empleados y terceros, el valor de los activos accesibles y derechos sobre el cierre de las actividades, por ejemplo.

En las organizaciones, el nivel de protección que requieren los distintos controles de acceso está determinado por el análisis/evaluación de riesgos. Por lo tanto, se debe prestar atención a los resultados obtenidos con esta actividad para determinar las medidas de seguridad adecuadas con el fin de, por ejemplo:

- » Definir los perímetros de seguridad para la seguridad física y el ambiente;
- » Proteger adecuadamente los equipos (internos o externos a las instalaciones de la organización) contra acceso no autorizado, pérdida o daños, peligros del propio ambiente, fuga de información, entre otros;
- » Evaluar si es adecuado destruir cierto dispositivo que almacena la información crítica para el negocio de la organización, o si es apropiado enviarlo para su reparación en el lugar autorizado por el fabricante del dispositivo;
- » Reducir al mínimo el riesgo de corrupción de los sistemas operativos, garantizando que la actualización se lleve a cabo sólo por personas competentes y autorizadas;
- » Reducir el riesgo de amenazas tales como robo, incendio, explosiones, polvo, efectos químicos, inundaciones, fallas en suministro de energía eléctrica, etc.
- » La educación y la sensibilización de los usuarios es fundamental para la seguridad de la información, dado que el uso adecuado de los recursos y la información, como “herramientas” de trabajo, fortalece la cultura de seguridad de la organización en conjunto.

Hay una serie de riesgos relacionados directamente con el control inadecuado de acceso lógico a los recursos de información. He aquí algunos ejemplos: la divulgación no autorizada de la información; modificaciones no autorizadas a los datos y aplicaciones y la introducción de los códigos maliciosos en los sistemas.

Así, la ausencia o la insuficiencia de los controles de acceso lógico afectan directamente a los recursos y la información, aumentando los ries-

gos. Por otra parte, los impactos pueden ser más grandes dado que consideramos las aplicaciones y la información crítica para el negocio de la organización. Si existen obligaciones legales involucradas con el control de acceso lógico, la organización puede sufrir demandas.

Como se ve en el ejemplo anterior, es importante tener en cuenta las medidas de seguridad adecuadas para efectuar el control de acceso lógico en las organizaciones. Por lo tanto se recomiendan algunas prácticas:

- » La restricción y monitoreo del acceso a los recursos críticos de la organización, tales como servidores, documentos, etc.;
- » El uso de cifrado fuerte, asegurando la confidencialidad de la información;
- » No guardar las contraseñas en los *logs* debido a que permite el posterior acceso de personas no autorizadas;
- » Concientizar a las personas de no divulgar sus contraseñas, ya sea verbalmente o por correo electrónico, ni almacenarlas en archivos;
- » Conceder acceso a las personas solamente a los recursos que son necesarios para ejecutar sus actividades.

Existen varios riesgos relacionados directamente con el control inadecuado de acceso físico en las organizaciones. Algunos ejemplos: el robo de los equipos o sus componentes internos y los actos de vandalismo como el corte de cables eléctricos. Así, la ausencia o la insuficiencia de los controles de acceso físico también pueden facilitar el trabajo a los invasores que atacan directamente a los controles de acceso lógico aplicados a los recursos de información.

Ejemplos de tratamientos para un adecuado control de acceso físico:

- » Identificar a los empleados y visitantes.
- » Controlar la entrada/salida de equipos.
- » Supervisar el desempeño del personal de limpieza, mantenimiento y vigilancia.

Como se ve en el ejemplo anterior, es importante tener en cuenta las medidas de seguridad adecuadas para llevar a cabo el control de acceso físico en las organizaciones. Por lo tanto, se recomiendan algunas prácticas:

- » Establecer formas de identificación que distingan entre empleados y visitantes;
- » Controlar la entrada y salida de equipos, registrando por ejemplo, la fecha, la hora y el responsable;

- » Supervisar las actividades de los equipos de limpieza, mantenimiento y vigilancia, sobre todo si son tercerizados.

Existen varios riesgos directamente relacionados con el control ambiental inadecuado o inexistente. Como ejemplos, considere los desastres naturales y fallas en el suministro de electricidad.

Los impactos incluyen daños a los equipos, la pérdida de datos o la falta de disponibilidad de los servicios, por ejemplo, generando pérdidas financieras y de imagen de la organización.

Ejercicio de refuerzo – el tratamiento del riesgo en la seguridad de acceso

- » ¿Qué riesgos en la seguridad de acceso puede identificar dentro de su entorno en su organización?
- » ¿Qué medidas va a proponer para el tratamiento de los riesgos en la seguridad de acceso de su organización?

5.15 El tratamiento de los riesgos en seguridad de las comunicaciones

Para garantizar la seguridad de las comunicaciones, es importante tener en cuenta el análisis/evaluación de riesgos con el fin de adecuar las medidas de seguridad a los requisitos de información necesarios para el negocio de la organización. También se recomienda la gestión de las comunicaciones.

En este contexto, se recomiendan algunas prácticas:

- » Las conexiones seguras que proporcionan servicios de red, especialmente los que operan directamente con la información crítica y las aplicaciones de negocio de la organización;
- » Identificar las medidas de seguridad adecuadas para la comunicación inalámbrica, tales como autenticación fuerte y selección de frecuencias;
- » Establecer la revisión periódica de los derechos de acceso a la red y sus servicios, asignados a los empleados, contratistas, colaboradores etc.

Ejercicio de refuerzo - el tratamiento de los riesgos en seguridad de las comunicaciones

- » ¿Qué medidas va a proponer para el tratamiento de los riesgos en la seguridad de las comunicaciones en su organización?

5.16 El tratamiento de riesgos y el negocio

La seguridad de la información debe ser adecuada para garantizar la protección de los recursos y la información de la organización, de acuerdo con sus objetivos de negocio. En este contexto, algunas consideraciones deben ser tenidas en cuenta. Por ejemplo:

- » Los riesgos relacionados directamente con aplicaciones críticas de negocio, en términos principalmente de la utilización de los recursos y la información compartida;
- » Gestionar adecuadamente las nuevas situaciones que influyen en el intercambio de información y recursos, tal como los nuevos contratos o sociedades, con el objetivo de tratar los posibles riesgos de acceso no autorizado;
- » En cuanto al uso de la criptografía, se debe considerar el tipo y calidad de los algoritmos adecuados a las necesidades. Es aconsejable desarrollar una política que aclare el modo de funcionamiento correcto, lo que reduce el riesgo de un mal uso, por ejemplo;
- » Todos los cambios deben ser controlados, y los riesgos y los impactos involucrados deben ser considerados para determinar las medidas de seguridad adecuadas;
- » En particular, la gestión de la continuidad del negocio debería incluir mecanismos para identificar y reducir los riesgos, para complementar el análisis / evaluación global de riesgos, ayudando fácilmente procesos que requieren respuestas inmediatas.

Las copias de seguridad (*backups*) son una herramienta importante para apoyar la continuidad de los servicios y por lo tanto el negocio; sin embargo, los riesgos asociados con los procedimientos inadecuados de copias rutinarias de seguridad regulares causan impactos tal como desperdicio de tiempo y recursos, y, en consecuencia, pérdidas financieras. Por ello, se recomienda a las organizaciones tomar medidas tales como una política formal de copia de seguridad y la capacitación y sensibilización continua de los empleados en cuanto a seguridad (incluyendo orientación sobre copias de seguridad personales).

Los siguientes son algunos riesgos e impactos que se presentan relacionados directamente con problemas con la contratación de servicios de terceros. Entre los riesgos, podemos destacar la incertidumbre de que el tercero (o prestador de servicios) emplee medidas de seguridad acordes con las adoptadas en la organización, teniendo en cuenta todas las normas de la organización.

Ejemplos de tratamiento para el control adecuado de la contratación de terceros:

- » Definir cláusulas contractuales que responsabilicen al tercero por la seguridad.
- » Definir cláusulas contractuales que permitan actualizaciones en los servicios y sistemas.

Para hacer frente a los riesgos como los presentados en el ejemplo anterior, algunas medidas se recomiendan: establecer cláusulas contractuales que definan claramente las responsabilidades del tercero relacionadas con la seguridad de la organización, e incluir cláusulas contractuales que permitan cambios en los servicios y sistemas en función de los nuevos objetivos de negocio.

Para pensar



Un contrato de prestación de servicios deberá incluir al menos los siguientes elementos: costos básicos, los derechos de las partes (al final del contrato); compensación en caso de pérdida, los derechos de propiedad de la información, los derechos de propiedad intelectual, la transferencia de la información y la documentación técnica; posibilidad de cambio, las normas de seguridad de la organización y las normas de calidad.

Ejemplos de cláusula contractual de seguridad de la información:

“Es obligación del **contratista** siempre que utilice el sistema con una conexión a los sistemas del **contratante**: cuando así lo solicite por escrito al **contratante**, realizar los cambios necesarios para remediar los problemas potenciales de seguridad o de vulnerabilidad en los sistemas que han sido notificados por el **contratante**.”

El control de la organización consta de todos los aspectos relacionados con la protección de la organización, de acuerdo con sus objetivos teniendo como base los riesgos, tales como: violación no autorizada de acceso a los recursos de información, el robo de los equipos y la planificación inadecuada del crecimiento computacional.

Ejemplos de tratamiento para el control adecuado de la organización:

- » Definir las responsabilidades de cada cargo en la jerarquía de la organización.
- » Cumplir con la legislación vigente.

Para el ejemplo anterior, algunas recomendaciones sobre las medidas de seguridad son directamente aplicables:

- » Definir las responsabilidades de los cargos de acuerdo con la jerarquía de la organización, de manera que las actividades se lleven a cabo correctamente.
- » Cumplir con la legislación vigente y los requisitos contractuales y reglamentarios relativos a la seguridad en la organización.

Un control adecuado de cambios en las organizaciones debe proporcionar soluciones a los riesgos tales como:

- » El uso de hardware y software no autorizado;
- » Dificultad de mantenimiento debido a la falta de documentación y procedimientos;
- » Los cambios inesperados o accidentales.

Se proponen algunas medidas de seguridad para el control adecuado de los siguientes cambios:

- » Documentar todos los cambios y actualizaciones realizadas y ponerlas en práctica sólo con la debida autorización;
- » Evaluar el impacto de los cambios antes de implementarlos;
- » Definir el procedimiento en situaciones de emergencia;
- » Planificar cambios para minimizar el impacto en el día a día de la organización.

5.17 La comunicación de riesgos

Esta actividad abarca todas las acciones para la divulgación de los riesgos, con el fin de informar y orientar a los participantes, buscando con ello la reducción (y, a menudo la eliminación) del riesgo en la organización.